Executive Summary

This vulnerability assessment evaluated the OWASP Juice Shop application within an authorized cybersecurity laboratory environment. OWASP ZAP was used to perform automated application discovery, passive analysis, and active vulnerability scanning. Findings generated by the automated scanner were subsequently reviewed and manually verified to distinguish confirmed vulnerabilities from potential or false-positive findings.

Assessment Scope

Target:
OWASP Juice Shop

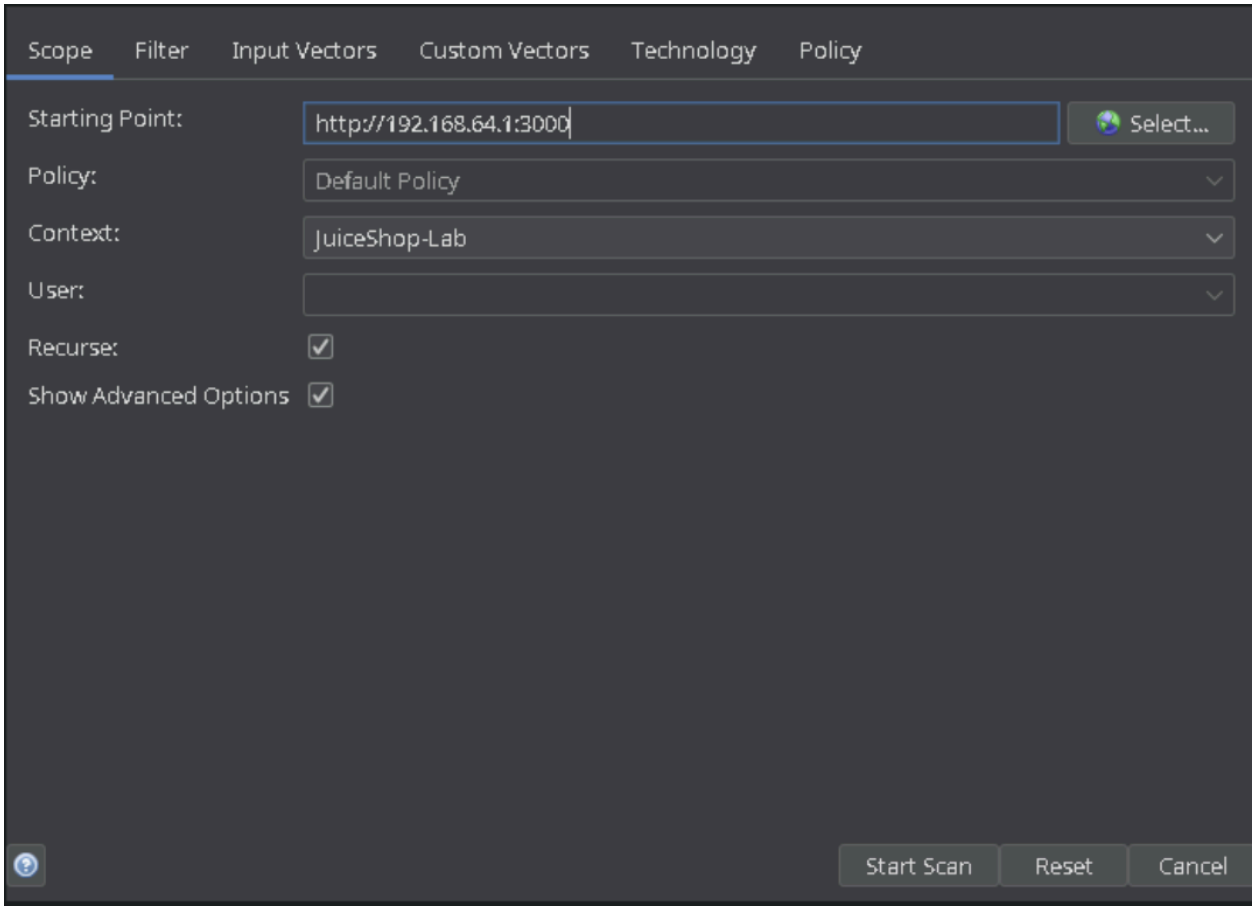
Target URL:
http://192.168.64.1:3000

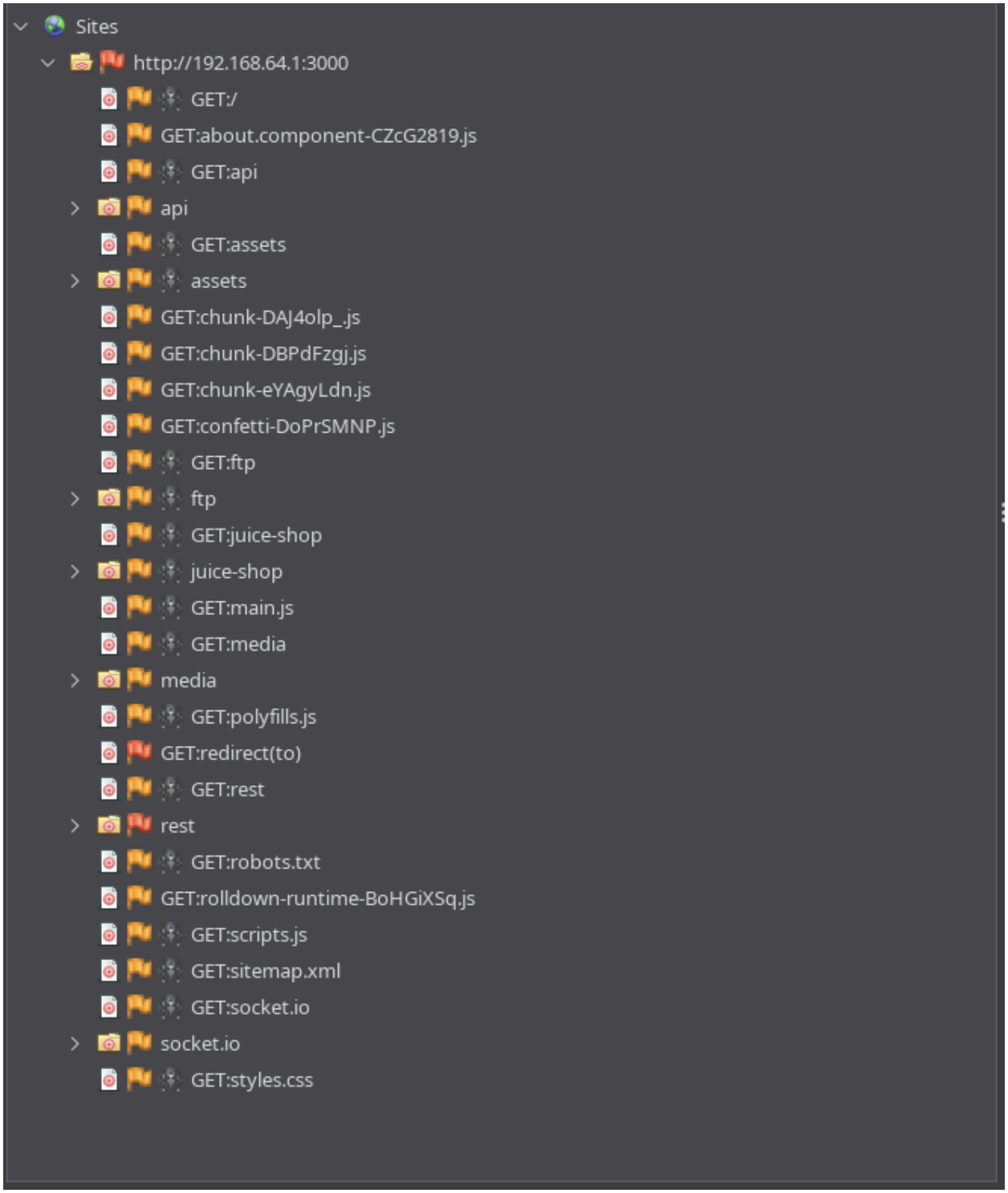
Testing Environment:
Local cybersecurity laboratory

Tool:
OWASP ZAP

Testing Period:
September 28-December 3

Authorization:
Authorized educational testing environment

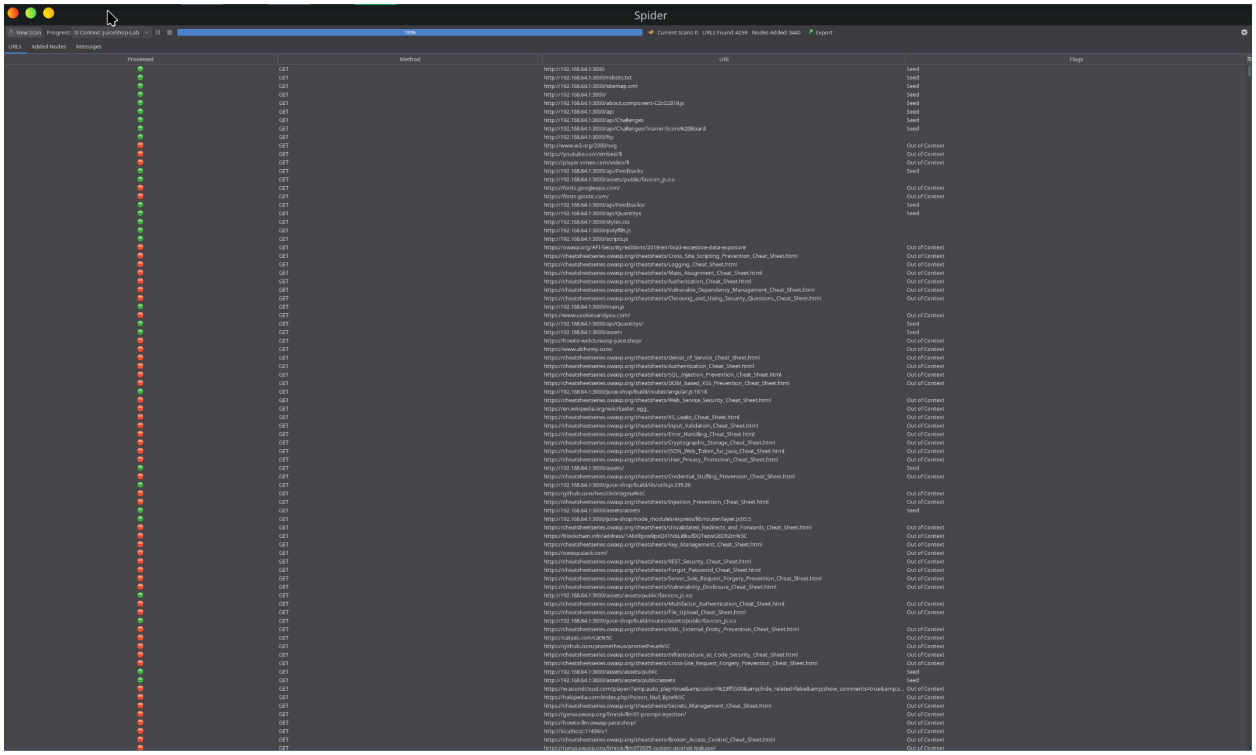

Scope
Filter
Input Vectors
Custom Vectors
Technology
Policy
Starting Point:
http://192.168.64.1:3000
Select...
Policy:
Default Policy
Context:
JuiceShop-Lab
User:
Recurse:
Show Advanced Options
Start Scan
Reset
Cancel



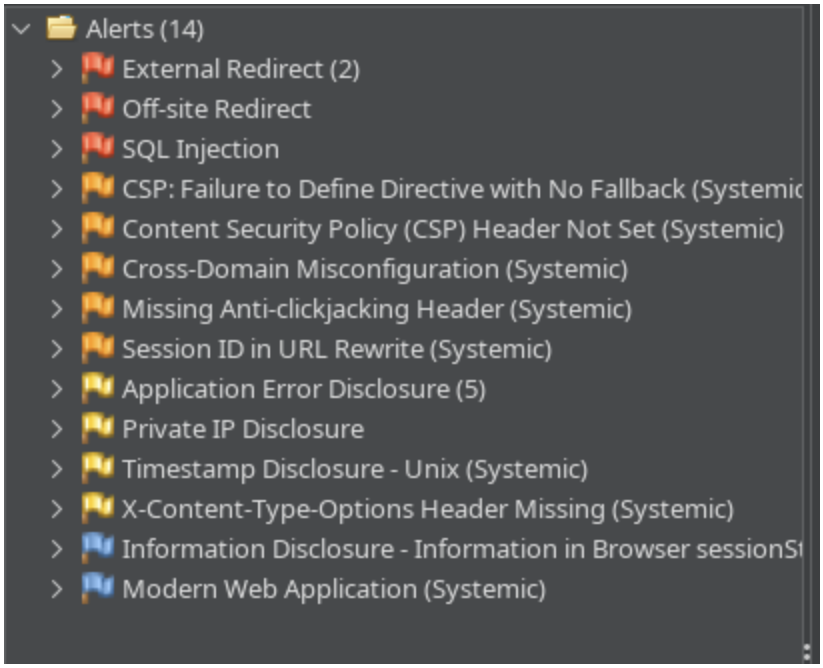
Methodology

1. Define assessment scope
2. Configure ZAP Context
3. Explore application
4. Spider application

5. Passive scanning
6. Active scanning
7. Review alerts
8. Select findings
9. Manually verify findings
10. Analyze risk
11. Develop remediation recommendations
12. Generate final report



Technical Findings



V-001 — SQL Injection

Confirmed

Description

OWASP ZAP's active scanner identified a potential SQL injection vulnerability in the q query-string parameter of the Juice Shop product-search endpoint. ZAP assigned the finding a High risk rating but Low confidence. The scanner's test resulted in an HTTP 500 Internal Server Error.

Automated Detection

Field	ZAP result
Finding	**SQL Injection**

Risk	**High**
Confidence	**Low**
URL	`http://192.168.64.1:3000/rest/products/search?q=...`
Parameter	`q`
Attack	`'(` / quote-based input
Evidence	`HTTP/1.1 500 Internal Server Error`
CWE	**CWE-89**
Scanner	Active Scan
Input vector	URL Query String

Manual Verification

The finding was manually tested by establishing a baseline response using a normal search query and then submitting controlled SQL injection test input to the `q` parameter. The responses were compared to determine whether the application's behavior was

consistent with SQL injection. Manual testing was performed against the affected `q` parameter. A baseline request using `q=apple` returned HTTP 200 and three matching products. A Boolean-based SQL injection test using `q=' OR '1'='1` also returned HTTP 200, but caused the endpoint to return a substantially larger product set rather than only the products matching "apple."

Evidence





Impact

Successful exploitation of the SQL injection vulnerability could allow an attacker to manipulate the application's database query through the `q` parameter. Depending on the

privileges of the application's database account and the affected query, this could result in unauthorized access to database information, modification or deletion of data, application-logic bypass, or disruption of database operations.

Remediation

Replace dynamically constructed SQL statements with parameterized queries/prepared statements. Validate the `q` parameter according to expected search-input requirements and ensure that the application's database account operates with the minimum privileges necessary. Database error details should not be exposed to users. After remediation, repeat the SQL injection tests to verify that SQL syntax supplied through `q` is treated as data rather than executable SQL.

V-002 — External Redirect

Severity: High
Confidence: Medium
Status: Confirmed
Affected URL: http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop
Parameter: to

Description:
OWASP ZAP identified an external redirect associated with the Juice Shop application. The alert was investigated to determine whether the redirect destination could be influenced by user-controlled input.

Automated Detection:
ZAP's Active Scanner identified two instances of the External Redirect alert. The affected request and response were reviewed to identify the redirect mechanism.

Manual Verification:
The redirect functionality was manually tested by supplying an external URL through the `to` parameter:

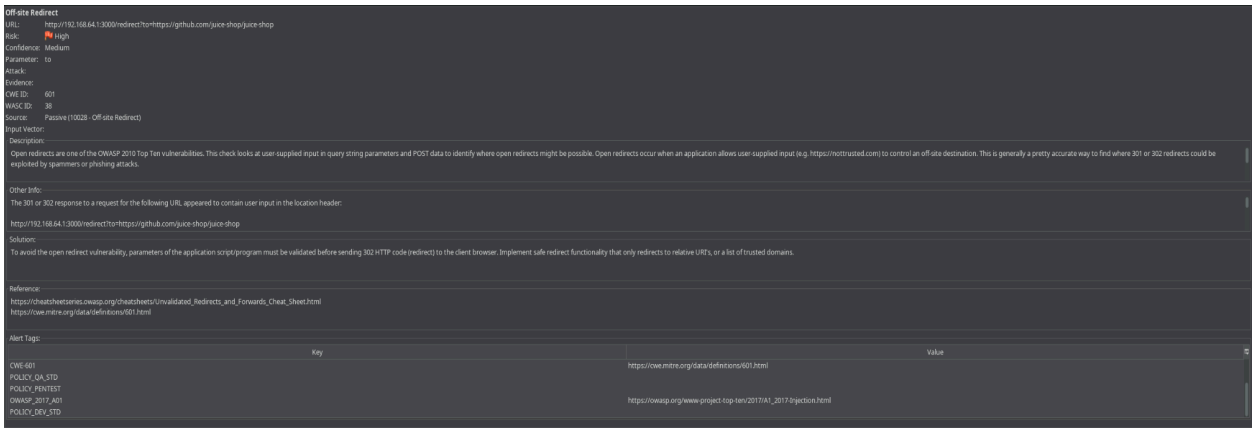
```
http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop
```

The application returned an HTTP `302 Found` response with the following `Location` header:

```
Location: https://github.com/juice-shop/juice-shop
```

This confirms that the application accepts an externally controlled destination and instructs the client to navigate to the external domain.

Evidence




```
DAEDMAC1010:dae_6month_ad Adult$ curl -i http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop
HTTP/1.1 302 Found
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: https://github.com/juice-shop/juice-shop
Vary: Accept, Accept-Encoding
Content-Type: text/plain; charset=utf-8
Content-Length: 62
Date: Tue, 29 Sep 2026 17:25:19 GMT
Connection: keep-alive
Keep-Alive: timeout=5

Found. Redirecting to https://github.com/juice-shop/juice-shopDAEDMAC1010:dae_6month_ad Adult$
```

Impact:
If the redirect destination is externally controllable, an attacker could potentially use the application's trusted URL to redirect users to an attacker-controlled website, potentially supporting phishing or other social-engineering activity.

Remediation:
Restrict redirects to approved internal paths or an allowlist of trusted destinations. Do not allow arbitrary user-supplied external URLs to determine redirect destinations. Re-test the affected endpoint after remediation.

V-003 — CSP: Failure to Define Directive with No Fallback

Description:
The observed Content-Security-Policy header defines `default-src 'none'` but does not

define the `frame-ancestors` or `form-action` directives. These directives do not fall back to `default-src`. Consequently, the policy does not explicitly restrict which sites can frame the application or where forms can submit data. The potential impact depends on the application's behavior and the policy applied to the final page.

Recommendation:

Review the application's intended security requirements and explicitly configure the missing directives. For example, if the application should not be embedded by other sites, consider `frame-ancestors 'none'`. Restrict `form-action` to the destinations required by the application, such as `form-action 'self'`, if appropriate. Test the updated policy to ensure legitimate application functionality continues to work.

Affected Application:
OWASP Juice Shop

Affected URL:

http://192.168.64.1:3000/assets

Manual Verification

The finding was manually verified by inspecting the HTTP response from the affected endpoint. The `/assets` endpoint returned an HTTP 301 response containing the following Content-Security-Policy header:

```
Content-Security-Policy: default-src 'none'
```

This confirms the CSP configuration identified by ZAP is present in the application's response.

Evidence



```
[DAEDMAC1010:dae_6month_ad Adult$ curl -s -D - -o /dev/null "http://192.168.64.1:3000/assets"
HTTP/1.1 301 Moved Permanently
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/html; charset=UTF-8
Content-Length: 156
Content-Security-Policy: default-src 'none'
Location: /assets/
Vary: Accept-Encoding
Date: Tue, 29 Sep 2026 17:52:11 GMT
Connection: keep-alive
Keep-Alive: timeout=5

DAEDMAC1010:dae_6month_ad Adult$
```

```
[DAEDMAC1010:dae_6month_ad Adult$ curl -s -D - -o /dev/null http://127.0.0.1:3000/assets/
 HTTP/1.1 200 OK
 Access-Control-Allow-Origin: *
 X-Content-Type-Options: nosniff
 X-Frame-Options: SAMEORIGIN
 Feature-Policy: payment 'self'
 X-Recruiting: /#/jobs
 Accept-Ranges: bytes
 Cache-Control: public, max-age=0
 Last-Modified: Wed, 28 Oct 2026 16:06:26 GMT
 ETag: W/"24b1-1a183434529"
 Content-Type: text/html; charset=UTF-8
 Content-Length: 9393
 Vary: Accept-Encoding
 Date: Wed, 28 Oct 2026 16:07:53 GMT
 Connection: keep-alive
 Keep-Alive: timeout=5

[DAEDMAC1010:dae_6month_ad Adult$ curl -s -D - -o /dev/null http://127.0.0.1:3000/
 HTTP/1.1 200 OK
 Access-Control-Allow-Origin: *
 X-Content-Type-Options: nosniff
 X-Frame-Options: SAMEORIGIN
 Feature-Policy: payment 'self'
 X-Recruiting: /#/jobs
 Accept-Ranges: bytes
 Cache-Control: public, max-age=0
 Last-Modified: Wed, 28 Oct 2026 16:06:26 GMT
 ETag: W/"24b1-1a183434529"
 Content-Type: text/html; charset=UTF-8
 Content-Length: 9393
 Vary: Accept-Encoding
 Date: Wed, 28 Oct 2026 16:08:19 GMT
 Connection: keep-alive
 Keep-Alive: timeout=5
```

Evidence:

- **ZAP alert identifying the missing directives.**

- **HTTP response headers showing `Content-Security-Policy: default-src 'none'`.**
- **The HTTP 301 redirect from `/assets` to `/assets/`.**

Potential Impact

The finding indicates that the application's CSP configuration may not explicitly define all applicable resource directives. This can reduce the clarity and predictability of the policy and may limit CSP's effectiveness as a defense-in-depth control. The actual security impact depends on the resource types used by the application and the other CSP directives configured.

Recommended Remediation

Review the application's CSP and explicitly define appropriate directives for the resource types used by the application. Maintain restrictive source values and use `default-src 'none'` as a restrictive baseline where appropriate. Test the resulting policy to ensure that required application functionality continues to operate while unnecessary resource sources remain blocked.

Risk Priority

ID	Finding	Risk Level	Potential Impact	Exploitability	Priority	Recommended Action
V-001	SQL Injection	**High**	Potential unauthorized database access, data disclosure, modification, or other application compromise depending on the vulnerable query	**High** — demonstrated through a crafted input	**1 — Highest**	Remediate first; use parameterized queries/prepared statements, input validation, and least-privilege database accounts

V-002	External Redirect	**Medium**	Users can potentially be redirected from a trusted application URL to an external website, which could support phishing or malicious-content delivery	**High** — demonstrated by the `302` response and external `Location` header	**2**	Restrict redirect destinations to approved domains or internal relative paths
V-003	CSP: Failure to Define Directive with No Fallback	**Low**	May reduce the effectiveness or predictability of CSP as a defense-in-depth control.	**Low/Context-dependent** — ZAP identified the CSP configuration, but manual test did not demonstrate direct exploitation	**3**	Review and explicitly define appropriate CSP directives; retain restrictive source policies